SPECIFICATION DOCUMENT

Singapore AI Safety Framework

Internal Control Specification for AI Governance

Version	**1.0.0**
Reference	SG-SAFETY-2026-v1.0
Date	April 2026
Author	SCB GCFO, AI Research & Development

Contents

Executive Summary 11

1 Normative Source Hierarchy 15

1.1 Why a source hierarchy matters . . . 15

1.2 Source precedence . . . 16

1.3 Normative Singapore sources . . . 16

1.4 Source class descriptions . . . 16

1.4.1 SG-01: IMDA Model Governance Framework for Agentic AI . . . 16

1.4.2 SG-02: IMDA Starter Kit for Testing LLM-Based Applications . . . 17

1.4.3 SG-03: PDPC Model AI Governance Framework . . . 18

1.4.4 SG-04: PDPC Advisory Guidelines on Personal Data in AI . . . 18

1.4.5 SG-05: IMDA Project Moonshot / AI Verify . . . 18

1.4.6 SG-07: CSA Guidelines on Securing AI Systems . . . 19

1.4.7 SG-08: CSA Agentic AI Addendum (Consultation) . . . 19

1.5 Source document locations . . . 19

1.6 Cross-referencing peer specifications . . . 20

2 System Use Cases in Scope **21**

2.1 Use-case inventory purpose . . . 21

2.2 Operational use-case inventory . . . 22

2.3 Use-case descriptions . . . 23

2.3.1 UC-01: Chat and prompt-response synthesis . . . 23

2.3.2 UC-02: AI-generated UI actions . . . 23

2.3.3 UC-03: HANA query and data-product prompts . . . 23

2.3.4 UC-08: Training and deployment . . . 24

2.3.5 UC-10: Agent/tool orchestration (MCP) . . . 24

2.4 Risk tier definitions . . . 24

2.5 Use-case registration process . . . 25

3 Control Framework **27**

3.1 Control design principles . . . 27

3.2 Mandatory control catalogue . . . 28

3.3 Critical controls . . . 30

3.4 Control category descriptions . . . 30

3.4.1 Governance controls (GOV) . . . 30

3.4.2 Data controls (DATA) . . . 31

3.4.3 Agent controls (AGT) . . . 31

3.4.4 Human controls (HUM) . . . 31

3.4.5 Security controls (SEC) . . . 32

3.4.6 Evaluation controls (EVAL) . . . 32

3.4.7 Monitoring controls (MON) . . . 32

3.4.8 User controls (USR) . . . 33

3.5 Control-to-source traceability . . . 33

4 Risk Scoring Model **35**

4.1 Purpose of risk scoring . . . 35

4.2 Normalized risk factors . . . 36

4.3 Inherent Risk Score (IRS) . . . 36

4.3.1 IRS interpretation . . . 37

4.3.2 Worked example: UC-10 Agent/tool orchestration . . . 37

4.4 Applicability-Weighted Control Coverage (AWCC) . . . 38

4.4.1 AWCC interpretation . . . 38

4.5 Penalty terms . . . 39

4.6 Residual Risk Score (RRS) . . . 39

4.6.1 RRS interpretation . . . 39

4.7 Deployment Readiness Score (DRS) . . . 40

4.7.1 DRS interpretation . . . 40

4.8 Production gate summary . . . 41

5 Metrics and Mathematical Gate Model 43

5.1 Purpose of quantitative metrics . . . 43

5.2 Mandatory metric set . . . 44

5.3 Formal metric definitions . . . 44

5.3.1 M-01: Policy Adherence Rate (PAR) . . . 45

5.3.2 M-02: Tool Call Accuracy (TCA) . . . 45

5.3.3 M-03: High-Stakes Checkpoint Coverage (HCC) . . . 45

5.3.4 M-04: Audit Trace Completeness (ATC) . . . 46

5.3.5 M-05: Adversarial Defense Rate (ADR) . . . 46

5.3.6 M-06: Data Leakage Rate (DLR) . . . 46

5.3.7 M-07: Hallucination/Error Rate (HER) . . . 47

5.3.8 M-08: Unauthorized Access Rate (UAR) . . . 47

5.3.9 M-09: Sandbox Enforcement Ratio (SER) . . . 47

5.4 Statistical evaluation rules . . . 48

5.4.1 Wilson Lower Confidence Bound . . . 48

5.4.2 Why Wilson bounds? . . . 48

5.4.3 Worked example . . . 48

5.5 Minimum sample sizes . . . 49

5.6 Composite evaluation score . . . 49

5.6.1 EVAL interpretation . . . 50

5.7 Metric thresholds summary . . . 50

5.8 Domain-Specific Metrics: Text-to-SQL . . . 51

5.8.1 TTS Metric Summary . . . 51

5.8.2 TTS-EVAL Composite Score . . . 52

5.8.3 TTS Metric Thresholds . . . 52

5.8.4 Relationship to Core Safety Metrics . . . 52

5.9 Persona-Aware Safety Metrics (PER-M01 to PER-M04) . . . 54

5.9.1 Metric Definitions . . . 54

5.9.2 PER-M01: Persona Coverage Rate . . . 54

5.9.3 PER-M02: Expertise Consistency Rate . . . 55

5.9.4 PER-M03: Cross-Persona Fairness . . . 55

5.9.5 PER-M04: Per-Persona Drift Score . . . 55

5.9.6 Persona Metric Thresholds . . . 56

5.9.7 Relationship to Core Safety Metrics . . . 56

6 Monitoring, Alerting, and Audit Schema 57

6.1 Monitoring objectives . . . 57

6.2 Required audit schema . . . 58

6.3 Identity attribution requirements . . . 58

6.3.1 Agent identity fields . . . 58

6.3.2 Request identity fields . . . 59

6.4 Audit reservation pattern . . . 59

6.5 Alert severity classes . . . 60

6.6 Condition codes . . . 60

6.7 Circuit-break rules . . . 60

6.8 Drift and anomaly detection . . . 62

6.8.1 Population Stability Index (PSI) . . . 62

6.8.2 Robust Z-Score . . . 62

6.9 Required alert payload . . . 63

6.10 Operator triage checklist . . . 64

6.11 Minimum evidence to close an alert . . . 64

7 Implementation Design **65**

7.1 Repository structure . . . 65

7.2 Governance module architecture . . . 65

7.2.1 Identity module (`identity.py`) . . . 66

7.2.2 Audit module (`audit.py`) . . . 66

7.2.3 Governed agent (`governed_agent.py`) . . . 67

7.3 JSON schemas . . . 67

7.4 Agent rule packs . . . 67

7.4.1 Development pack (`.clinerules`) . . . 68

7.4.2 Runtime-monitor pack (`.clinerules.runtime-monitor`) . . . 68

7.5 Compliance requirements mapping . . . 69

7.6 Integration points . . . 69

7.6.1 MCP tool allow-list . . . 69

7.6.2 Approval-required tools . . . 70
7.6.3 Audit database schema . . . 70
7.7 Testing and validation . . . 71
7.7.1 Validation harness . . . 71
7.7.2 Running validation . . . 71
7.8 Deployment checklist . . . 72

8 References **73**

8.1 Singapore Government sources . . . 73
8.1.1 Primary normative sources . . . 73
8.1.2 Supplementary sources . . . 74
8.2 Open-source tools and frameworks . . . 74
8.3 Internal specifications . . . 75
8.4 JSON schemas . . . 75
8.5 Source document locations . . . 76
8.6 Version history . . . 76
8.7 Document control . . . 77

9 Global Wave-Dependency Manifest **79**

9.1 Critical Path Visualization (Waves 1–3) . . . 79
9.2 Inter-Domain Prerequisite Matrix . . . 80

Executive Summary

This specification establishes a single governance baseline across all AI-enabled system surfaces in the SAP-OSS repository. The framework is aligned with Singapore's regulatory guidance on AI governance and safety, particularly:

- IMDA Model AI Governance Framework for Agentic AI (January 2026)
- IMDA Starter Kit for Testing LLM-Based Applications
- PDPC Model AI Governance Framework (Second Edition)
- PDPC Advisory Guidelines on Use of Personal Data in AI
- CSA Guidelines on Securing AI Systems

The specification covers five core artefacts:

1. **Normative source hierarchy** — exact regulatory documents and their precedence order
2. **System use-case inventory** — 12 operational use cases with risk classifications
3. **Mandatory control catalogue** — 23 controls with evidence requirements

4. **Quantitative metrics** — 12 metrics with mathematical scoring models
5. **Implementation design** — repository structure and compliance mapping

Universal Policy Position

Universal Governance Policy

No AI-enabled use case may enter production, or remain in production, unless it has:

1. a registered owner
2. a bounded use-case profile
3. a quantitative risk score
4. an applicable control profile
5. documented test results against thresholds
6. production monitoring and incident handling
7. a complete audit and evidence trail

Production Gate Summary

A use case is eligible for production deployment if and only if:

1. Residual Risk Score (RRS) ≤ 45
2. Deployment Readiness Score (DRS) ≥ 70
3. All critical controls pass
4. All metric LCB_{95} values meet thresholds

Contents

CHAPTER 1

1 Normative Source Hierarchy

1.1 Why a source hierarchy matters

Singapore's AI governance landscape comprises multiple overlapping documents from different agencies (IMDA, PDPC, CSA) with different publication statuses (official, consultation, reference). Without explicit precedence, an organisation cannot answer the question *"Which source should I follow when guidance conflicts?"*

This chapter establishes the authoritative ordering and explains how each source class contributes to the overall framework.

1.2 Source precedence

Sources are applied in the following order:

1. **Normative Singapore governance baseline**: Official IMDA and PDPC guidance on AI governance, agentic AI, LLM testing, and personal data use in AI.
2. **Normative operational assurance baseline**: Official IMDA/AI Verify materials on LLM testing and AI assurance.
3. **Supplementary security baseline**: Official CSA secure-AI guidance, with explicit notation where guidance is draft or consultation-stage.
4. **Supporting reference material**: AI Verify open-source artefacts and academic references.

1.3 Normative Singapore sources

1.4 Source class descriptions

1.4.1 SG-01: IMDA Model Governance Framework for Agentic AI

The MGF for Agentic AI is the primary normative source. It defines four pillars:

1. **Pillar 1**: Assess and Bound Risks Upfront
2. **Pillar 2**: Make Humans Meaningfully Accountable
3. **Pillar 3**: Implement Technical Controls and Processes

Table 1.1 – Normative and Supplementary Source Set

ID	Source	Date	Role
SG-01	IMDA MGF for Agentic AI	Jan 2026	Primary normative baseline for agentic use-case selection, bounded autonomy, human accountability
SG-02	IMDA Starter Kit for LLM Testing	Jan 2026	Primary baseline for pre-deployment testing structure
SG-03	PDPC Model AI Governance Framework	Jan 2020	Baseline governance structure
SG-04	PDPC Advisory Guidelines (Personal Data in AI)	Apr 2024	PDPA-aligned data handling
SG-05	IMDA Project Moonshot / AI Verify	May 2024	Benchmarking and red-teaming
SG-06	Singapore's Approach to AI Governance	Ongoing	Practical risk-based position
SG-07	CSA Guidelines on Securing AI Systems	Oct 2024	Supplementary secure-by-design baseline
SG-08	CSA Agentic AI Addendum (Consultation)	Oct 2025	Supplementary security input (consultation-stage)

4. **Pillar 4**: Enable End-User Responsibility

Each requirement in this specification traces back to one or more MGF sections.

1.4.2 SG-02: IMDA Starter Kit for Testing LLM-Based Applications

Provides the structure for pre-deployment safety testing:

- Baseline safety evaluation methodology
- Statistical sufficiency requirements
- Red-teaming and adversarial testing guidance

1.4.3 SG-03: PDPC Model AI Governance Framework

The foundational governance document establishing:

- Named accountable ownership requirement
- Risk-based approach to AI deployment
- Internal governance structures

1.4.4 SG-04: PDPC Advisory Guidelines on Personal Data in AI

PDPA-aligned guidance for personal data handling:

- Lawful basis for AI processing
- Data minimisation requirements
- Retention and deletion obligations

1.4.5 SG-05: IMDA Project Moonshot / AI Verify

Operationalisation tooling:

- AI Verify benchmarking framework
- Moonshot red-teaming capabilities
- Testing artefact structure

1.4.6 SG-07: CSA Guidelines on Securing AI Systems

Security baseline covering:

- Secure-by-design principles
- Adversarial resilience
- Incident response

1.4.7 SG-08: CSA Agentic AI Addendum (Consultation)

> ⚠ Consultation-Stage Document
>
> This source is in public consultation as of October 2025. Requirements derived from SG-08 are marked as **supplementary** and may change when the final version is published.

Covers agentic-specific security concerns:

- Tool access sandboxing
- Agent identity attestation
- Least-privilege tool boundaries

1.5 Source document locations

Table 1.2 – Source Document Repository Paths

Source ID	Repository Path
SG-01	
	🗀 `docs/regulations/mgf-for-agentic-ai.pdf`
SG-02	
	🗀 `docs/regulations/aiverify-main/`
SG-05	
	🗀 `docs/regulations/moonshot-cicd-main/`
SG-06	
	🗀 `docs/pdf/technical-reports/06-singapore-ai-safety-framework.pdf`

1.6 Cross-referencing peer specifications

This specification cross-references the following peer documents:

- **Regulations Corpus** (🗀 `docs/latex/specs/regulations/`) — Agentic AI regulatory requirements and implementation evidence
- **Clinerules-Agents** (🗀 `docs/latex/specs/clinerules-agents/`) — Agent rule-pack architecture
- **TB-HITL Specification** (🗀 `docs/latex/specs/tb/`) — Trial Balance human-in-the-loop workflow

CHAPTER 2

2 System Use Cases in Scope

2.1 Use-case inventory purpose

Every AI-enabled capability in the repository must be registered as a use case before implementation begins. This chapter defines the operational use-case inventory that is subject to governance controls.

2.2 Operational use-case inventory

Table 2.1 – Use-Case Inventory for Committee Review

ID	Use Case	Action Type	Risk Tier	Core Risk Drivers
UC-01	Chat and prompt-response synthesis	Read/generate	Medium	Prompt injection, hallucination, confidentiality
UC-02	AI-generated UI actions	Assist/approve	High	Automation bias, hidden writes
UC-03	HANA query and data-product prompts	Read/query	High	Schema exposure, SQL guardrails
UC-04	Retrieval and vector operations	Read/write vectors	High	Sensitive ingestion, retrieval leakage
UC-05	Personal knowledge and memory	Read/write knowledge	High	Retention, user boundaries
UC-06	OCR document extraction	Read/extract	High	Document sensitivity, interpretation
UC-07	Data-cleaning workflows	Recommend/process	Medium	False assurance, traceability
UC-08	Training and deployment	Create/deploy	Critical	Provenance, validation sufficiency
UC-09	Pipeline orchestration	Automate workflow	High	Process chaining, silent failure
UC-10	Agent/tool orchestration (MCP)	Tool use/plan	Critical	Tool misuse, dynamic planning
UC-11	Governance and audit	Oversight/evidence	High	Approval integrity, completeness
UC-12	Local model serving	Inference runtime	High	Confidential routing, resilience

2.3 Use-case descriptions

2.3.1 UC-01: Chat and prompt-response synthesis

Description Interactive chat interfaces where users submit prompts and receive LLM-generated responses.

Action Type Read/generate — reads context, generates new content.

Risk Tier Medium

Primary Risks Prompt injection, hallucination, confidentiality leakage.

Key Controls `SEC-01`, `EVAL-01`, `USR-01`

2.3.2 UC-02: AI-generated UI actions

Description AI assists users by suggesting or executing UI actions based on context.

Action Type Assist/approve — proposes actions for human approval.

Risk Tier High

Primary Risks Automation bias, hidden writes to backend systems.

Key Controls `HUM-01`, `HUM-02`, `AGT-01`

2.3.3 UC-03: HANA query and data-product prompts

Description Natural language queries translated to SQL against SAP HANA.

Action Type Read/query — reads data, executes queries.

Risk Tier High

Primary Risks Schema exposure, SQL injection, guardrail bypass.

Key Controls `DATA-01`, `SEC-01`, `AGT-02`

2.3.4 UC-08: Training and deployment

Description Model training, fine-tuning, and deployment to production.

Action Type Create/deploy — creates new model artefacts.

Risk Tier Critical

Primary Risks Training data provenance, validation sufficiency.

Key Controls `GOV-03`, `EVAL-01`, `EVAL-03`

2.3.5 UC-10: Agent/tool orchestration (MCP)

Description Multi-step agent planning with tool invocation via MCP.

Action Type Tool use/plan — invokes external tools and services.

Risk Tier Critical

Primary Risks Tool misuse, dynamic planning errors, unbounded autonomy.

Key Controls `AGT-01`, `AGT-02`, `AGT-03`, `AGT-04`, `HUM-01`, `MON-01`

2.4 Risk tier definitions

Table 2.2 – Risk Tier Definitions

Tier	IRS Range	Description
Low	$0 \leq IRS < 25$	Minimal risk, standard controls
Medium	$25 \leq IRS < 50$	Moderate risk, enhanced controls
High	$50 \leq IRS < 75$	Significant risk, critical controls required
Critical	$75 \leq IRS \leq 100$	Highest risk, full control suite and review board

2.5 Use-case registration process

Before implementation, each use case must be registered with:

1. **Use-case card** — structured description including ID, name, action type, data classification, autonomy level
2. **Risk assessment** — calculated Inherent Risk Score (IRS)
3. **Control profile** — applicable controls identified
4. **Owner assignment** — named business and technical owners
5. **Ticket reference** — tracking ticket for governance approval

Registration is tracked in the use-case section of the regulations requirement corpus at `docs/regulations/machine-readable/specification-addendum.yaml` (key `use_cases`), validated against the schemas under `docs/schema/regulations/` via `docs/schema/validate.py`.

CHAPTER 3

3 Control Framework

3.1 Control design principles

Five principles guide the control framework design:

1. **Bound the use case** before building or deploying it.
2. **Make a human unambiguously accountable**.
3. **Treat tools, memory, and data access** as first-class risk surfaces.
4. **Require evidence-driven go/no-go decisions**.
5. **Monitor after deployment** because pre-deployment testing is necessary but insufficient.

3.2 Mandatory control catalogue

Table 3.1 – Mandatory Control Catalogue (23 Controls)

ID	Control	Requirement	Primary Evidence	Sources
GOV-01	Named accountable owner	Business owner, technical owner, security reviewer	Use-case registry, RACI	SG-01, SG-03
GOV-02	Use-case registration	Must register before implementation	Use-case card, ticket	SG-01, SG-03
GOV-03	Model/dependency inventory	All models and tools inventoried	Inventory table, SBOM	SG-01, SG-05,
DATA-01	Data classification	Classify as public/internal/confidential/personal/restricted	Data map, access matrix	SG-01, SG-03,
DATA-02	Data minimisation	Personal-data use documented and PDPA-aligned	DPIA/LIA, consent record	SG-04
DATA-03	Retention and deletion	Retention and purge rules defined	Retention schedule	SG-04, SG-07
AGT-01	Bounded autonomy	Maximum autonomy level declared	Autonomy classification	SG-01
AGT-02	Least-privilege tools	Explicit allow-list, least privilege	Tool allowlist, matrix	SG-01, SG-08
AGT-03	Agent identity	Unique identity and delegation record	Agent ID, approval logs	SG-01, SG-08
AGT-04	Sandboxing	High-risk execution sandboxed	Sandbox config	SG-01, SG-07,
HUM-01	Checkpoint design	High-stakes actions require human approval	Approval policies	SG-01, SG-03
HUM-02	Effective approval UX	Contextual, concise, auditable	Approval payload schema	SG-01

Continued on next

Table 3.1 – continued

ID	Control	Requirement	Primary Evidence	Sources
HUM-03	Oversight audit	Approvals sampled for effectiveness	QA sample pack	SG-01
SEC-01	Prompt-injection resilience	Defend against injection and exfiltration	Red-team results	SG-02, S
SEC-02	Trusted protocol boundary	Only approved MCP/APIs/services	Allowlist, trust review	SG-01, S
EVAL-01	Baseline safety evaluation	Test for hallucination, bias, leakage, adversarial	Test plan, benchmarks	SG-02, S
EVAL-02	Statistical sufficiency	Defined sample sizes and confidence methods	Sample design	SG-02
EVAL-03	Stage-gate deployment	Numeric readiness gates	Gate decision memo	SG-01, S
MON-01	Full audit trace	Every execution records required fields	Audit logs, completeness	SG-01, S
MON-02	Real-time anomaly monitoring	High-risk anomalies trigger alerts	Alert definitions, runbooks	SG-01, S
MON-03	Incident response and rollback	AI incidents triaged and contained	Incident tickets	SG-01, S
USR-01	User transparency	Users informed of AI involvement	UI notice, documentation	SG-01, S
USR-02	User and reviewer training	Training on failure modes and escalation	Training records	SG-01, S

3.3 Critical controls

The following controls are **critical controls**. They must pass with no exception for any high-risk or critical use case:

- `GOV-01`, `GOV-02` — Governance ownership
- `DATA-01` — Data classification
- `AGT-02`, `AGT-03` — Agent tool and identity
- `HUM-01` — Human checkpoint
- `SEC-01` — Prompt-injection resilience
- `EVAL-01`, `EVAL-03` — Evaluation and gating
- `MON-01`, `MON-02`, `MON-03` — Monitoring

Critical Control Requirement

A use case that fails any critical control cannot be approved for production.

3.4 Control category descriptions

3.4.1 Governance controls (GOV)

Governance controls ensure accountable ownership and proper registration:

`GOV-01` Every use case must have a named business owner (accountable for outcomes), technical owner (responsible for implementation), and security reviewer.

`GOV-02` Use cases must be registered in the governance system before implementation begins.

`GOV-03` All models, tools, and dependencies must be inventoried with version tracking and SBOM generation.

3.4.2 Data controls (DATA)

Data controls address classification, minimisation, and retention:

`DATA-01` All data must be classified according to sensitivity levels: public, internal, confidential, personal, restricted.

`DATA-02` Personal data use must be documented with lawful basis under PDPA and subject to minimisation requirements.

`DATA-03` Retention periods and purge schedules must be defined for all AI-processed data.

3.4.3 Agent controls (AGT)

Agent controls bound autonomy and tool access:

`AGT-01` Each agent must declare its maximum autonomy level (L1-Observe, L2-Collaborate, L3-Delegate, L4-Autonomous).

`AGT-02` Tools must be explicitly allow-listed; agents operate with least-privilege tool access.

`AGT-03` Each agent must have a unique identity with delegation records for audit attribution.

`AGT-04` High-risk agent executions must be sandboxed.

3.4.4 Human controls (HUM)

Human controls ensure meaningful human accountability:

`HUM-01` High-stakes actions must require human approval before execution.

`HUM-02` Approval UX must be contextual, concise, and provide actionable information.

`HUM-03` Approval decisions must be sampled and audited for effectiveness.

3.4.5 Security controls (SEC)

Security controls address adversarial resilience:

`SEC-01` Systems must defend against prompt injection, jailbreaking, and data exfiltration.

`SEC-02` Only approved MCP servers, APIs, and services may be accessed.

3.4.6 Evaluation controls (EVAL)

Evaluation controls ensure pre-deployment readiness:

`EVAL-01` Baseline safety evaluation must test for hallucination, bias, data leakage, and adversarial robustness.

`EVAL-02` Sample sizes and statistical methods must be defined to ensure confidence in results.

`EVAL-03` Numeric stage gates must be met before deployment proceeds.

3.4.7 Monitoring controls (MON)

Monitoring controls ensure post-deployment oversight:

`MON-01` Every governed execution must produce a complete audit record with required fields.

`MON-02` Real-time monitoring must detect anomalies and trigger alerts.

`MON-03` AI incidents must be triaged, contained, and rolled back when necessary.

3.4.8 User controls (USR)

User controls address transparency and training:

`USR-01` Users must be informed when they are interacting with AI-generated content or recommendations.

`USR-02` Users and reviewers must be trained on AI failure modes and escalation procedures.

3.5 Control-to-source traceability

Table 3.2 – Control-to-Source Traceability Matrix

Control	SG-01	SG-02	SG-03	SG-04	SG-05	SG-07	SG-08
GOV-01	✓		✓				
GOV-02	✓		✓				
GOV-03	✓				✓	✓	
DATA-01	✓		✓	✓			
DATA-02				✓			
DATA-03				✓		✓	
AGT-01	✓						
AGT-02	✓						✓
AGT-03	✓						✓
AGT-04	✓					✓	✓
HUM-01	✓		✓				
HUM-02	✓						
HUM-03	✓						
SEC-01		✓				✓	✓
SEC-02	✓						✓
EVAL-01		✓			✓		
EVAL-02		✓					
EVAL-03	✓	✓	✓				
MON-01	✓				✓		
MON-02	✓					✓	✓
MON-03	✓					✓	
USR-01	✓		✓	✓			
USR-02	✓		✓				

CHAPTER 4

4 Risk Scoring Model

4.1 Purpose of risk scoring

The risk scoring model provides a quantitative, repeatable method to:

1. Classify use cases into risk tiers (Low, Medium, High, Critical)
2. Determine applicable control profiles
3. Calculate residual risk after controls are applied
4. Gate production deployment based on numeric thresholds

4.2 Normalized risk factors

For each use case u, assign the following normalized factors in the interval $[0, 1]$:

Table 4.1 – Normalized Risk Factors

Factor	Name	Weight	Normalisation Rule
DS_u	Data sensitivity	0.20	Public=0.10, internal=0.35, confidential=0.70, personal=0.90, restricted=1.00
AA_u	Action authority	0.20	Read-only=0.10, internal write=0.50, external write=0.80, payment/delete/deploy=1.00
AU_u	Autonomy level	0.15	Human operates=0.10, collaborate=0.40, human approves critical=0.70, human observes only=1.00
EC_u	Environmental connectivity	0.15	None=0.10, internal services=0.40, third-party APIs=0.70, browser/MCP=1.00
RV_u	Irreversibility	0.10	Fully reversible=0.10, partially=0.60, irreversible=1.00
UI_u	User/legal impact	0.10	Low=0.20, medium=0.50, high=0.80, critical=1.00
MU_u	Model uncertainty	0.05	Deterministic=0.20, narrow model=0.50, general LLM=0.80, multi-agent=1.00
TD_u	Third-party dependency	0.05	None=0.10, controlled vendor=0.50, unverified=1.00

4.3 Inherent Risk Score (IRS)

The **Inherent Risk Score** for use case u is the weighted sum of normalized risk factors:

$$\boxed{IRS_u = 100 \times (0.20 \cdot DS_u + 0.20 \cdot AA_u + 0.15 \cdot AU_u + 0.15 \cdot EC_u + 0.10 \cdot RV_u + 0.10 \cdot UI_u + 0.05 \cdot MU_u + 0.05 \cdot TD_u)} \tag{4.1}$$

4.3.1 IRS interpretation

Table 4.2 – Inherent Risk Score Interpretation

Score Band	Tier	Control Implications
$0 \leq IRS < 25$	Low	Standard controls
$25 \leq IRS < 50$	Medium	Enhanced controls
$50 \leq IRS < 75$	High	Critical controls required
$75 \leq IRS \leq 100$	Critical	Full control suite + review board

4.3.2 Worked example: UC-10 Agent/tool orchestration

$$
\begin{aligned}
DS &= 0.70 \quad \text{(confidential data)} \\
AA &= 0.80 \quad \text{(external writes via MCP)} \\
AU &= 0.70 \quad \text{(human approves critical only)} \\
EC &= 1.00 \quad \text{(MCP/browser connectivity)} \\
RV &= 0.60 \quad \text{(partially reversible)} \\
UI &= 0.80 \quad \text{(high user impact)} \\
MU &= 1.00 \quad \text{(multi-agent)} \\
TD &= 0.50 \quad \text{(controlled vendor)}
\end{aligned}
$$

$$
\begin{aligned}
IRS &= 100 \times (0.20 \times 0.70 + 0.20 \times 0.80 + 0.15 \times 0.70 + 0.15 \times 1.00 \\
&\quad + 0.10 \times 0.60 + 0.10 \times 0.80 + 0.05 \times 1.00 + 0.05 \times 0.50) \\
&= 100 \times (0.14 + 0.16 + 0.105 + 0.15 + 0.06 + 0.08 + 0.05 + 0.025) \\
&= 100 \times 0.77 = \mathbf{77}
\end{aligned}
$$

Result: **Critical tier** ($IRS \geq 75$).

4.4 Applicability-Weighted Control Coverage (AWCC)

Let $a_{u,j} \in \{0,1\}$ indicate whether control j applies to use case u. Let $p_{u,j}$ be the control outcome score:

$$p_{u,j} = \begin{cases} 1.0 & \text{control passes} \\ 0.5 & \text{partial or compensating pass} \\ 0.0 & \text{control fails} \end{cases}$$

The **Applicability-Weighted Control Coverage** is:

$$\boxed{AWCC_u = \frac{\sum_{j=1}^{23} a_{u,j} \cdot p_{u,j}}{\sum_{j=1}^{23} a_{u,j}}} \tag{4.2}$$

4.4.1 AWCC interpretation

Table 4.3 – Control Coverage Interpretation

AWCC Range	Interpretation
$AWCC \geq 0.95$	Full coverage
$0.85 \leq AWCC < 0.95$	Acceptable with monitoring
$0.70 \leq AWCC < 0.85$	Gaps require remediation
$AWCC < 0.70$	Significant gaps, not production-ready

4.5 Penalty terms

Penalty terms add fixed risk points for specific control failures:

$$\boxed{Penalty_u = 15 \cdot N_u^{audit} + 15 \cdot N_u^{checkpoint} + 10 \cdot N_u^{external} + 20 \cdot N_u^{privacy}} \tag{4.3}$$

where:

- $N_u^{audit} = 1$ if full audit trace is missing (`MON-01` fails), else 0
- $N_u^{checkpoint} = 1$ if a required human checkpoint is missing (`HUM-01` fails), else 0
- $N_u^{external} = 1$ if untrusted external tools/services are used (`SEC-02` fails), else 0
- $N_u^{privacy} = 1$ if personal-data handling lacks lawful basis (`DATA-02` fails), else 0

4.6 Residual Risk Score (RRS)

The **Residual Risk Score** combines inherent risk, control coverage, and penalties:

$$\boxed{RRS_u = \min\left(100,\ IRS_u \times (1 - 0.55 \cdot AWCC_u) + Penalty_u\right)} \tag{4.4}$$

The 0.55 coefficient means that perfect control coverage ($AWCC = 1.0$) reduces inherent risk by 55%.

4.6.1 RRS interpretation

Production Gate

A use case with $RRS > 45$ cannot be approved for production deployment.

Table 4.4 – Residual Risk Score Interpretation

Score Band	Interpretation
$0 \leq RRS \leq 20$	Acceptable for defined control context
$20 < RRS \leq 30$	Acceptable with enhanced monitoring
$30 < RRS \leq 45$	Review-board approval required
$RRS > 45$	**Not production-ready**

4.7 Deployment Readiness Score (DRS)

The **Deployment Readiness Score** is a composite metric combining evaluation results, residual risk, control coverage, and training:

$$\boxed{DRS_u = 0.4 \cdot EVAL_u + 0.3 \cdot (100 - RRS_u) + 0.2 \cdot (AWCC_u \times 100) + 0.1 \cdot TC_u} \tag{4.5}$$

where:

- $EVAL_u$ is the evaluation score (see Chapter 5)
- RRS_u is the residual risk score
- $AWCC_u$ is the control coverage
- TC_u is the training coverage percentage

4.7.1 DRS interpretation

Table 4.5 – Deployment Readiness Score Interpretation

Score Band	Interpretation
$DRS \geq 85$	Fully ready for production
$70 \leq DRS < 85$	Ready with conditions
$55 \leq DRS < 70$	Needs improvement
$DRS < 55$	**Not ready for production**

4.8 Production gate summary

A use case u is eligible for production deployment if and only if:

1. $RRS_u \leq 45$ (residual risk within tolerance)
2. $DRS_u \geq 70$ (deployment readiness met)
3. All critical controls pass (see Chapter 3)
4. All metric LCB_{95} values meet thresholds (see Chapter 5)

All four conditions must be satisfied; failing any one blocks production deployment.

CHAPTER 5

5 Metrics and Mathematical Gate Model

5.1 Purpose of quantitative metrics

Metrics provide objective evidence of system behavior. This chapter defines:

1. 12 mandatory metrics linked to controls
2. Formal mathematical definitions
3. Statistical confidence requirements
4. Minimum sample sizes by risk tier

5.2 Mandatory metric set

Table 5.1 – Mandatory Quantitative Metrics (12 Metrics)

ID	Name	Definition	Control Link
M-01	Policy Adherence Rate (PAR)	Fraction of executions within approved policies	AGT-02, HUM-01
M-02	Tool Call Accuracy (TCA)	Fraction of tool invocations correct and in-policy	AGT-02, SEC-01
M-03	High-Stakes Checkpoint Coverage (HCC)	Fraction of high-stakes actions with approval	HUM-01, HUM-02
M-04	Audit Trace Completeness (ATC)	Fraction of events with all required audit fields	MON-01
M-05	Adversarial Defense Rate (ADR)	Fraction of adversarial tests safely handled	SEC-01, EVAL-01
M-06	Data Leakage Rate (DLR)	Fraction of tests exposing protected data	DATA-02, SEC-01
M-07	Hallucination/Error Rate (HER)	Fraction of unsupported claims	EVAL-01
M-08	Unauthorized Access Rate (UAR)	Attempts per 1,000 runs	AGT-02, MON-02
M-09	Sandbox Enforcement Ratio (SER)	Fraction of high-risk runs in sandbox	AGT-04, SEC-02
M-10	Mean Time to Escalation (MTTE)	Mean time to human ownership	MON-02, MON-03
M-11	Mean Time to Containment (MTTC)	Mean time to containment/rollback	MON-03
M-12	Oversight Effectiveness Failure (OFR)	Fraction of approvals overturned	HUM-03

5.3 Formal metric definitions

5.3.1 M-01: Policy Adherence Rate (PAR)

$$\boxed{PAR = \frac{N_{\text{policy-compliant executions}}}{N_{\text{governed executions}}}} \tag{5.1}$$

Direction Higher is better

Threshold $PAR \geq 0.95$ required

Controls `AGT-02`, `HUM-01`

5.3.2 M-02: Tool Call Accuracy (TCA)

$$\boxed{TCA = \frac{N_{\text{correct and authorised tool calls}}}{N_{\text{total tool calls}}}} \tag{5.2}$$

Direction Higher is better

Threshold $TCA \geq 0.90$ required

Controls `AGT-02`, `SEC-01`

5.3.3 M-03: High-Stakes Checkpoint Coverage (HCC)

$$\boxed{HCC = \frac{N_{\text{high-stakes events with valid approval}}}{N_{\text{high-stakes events}}}} \tag{5.3}$$

Direction Higher is better

Threshold $HCC = 1.00$ required (no exceptions)

Controls `HUM-01`, `HUM-02`

5.3.4 M-04: Audit Trace Completeness (ATC)

$$\boxed{ATC = \frac{N_{\text{events with complete audit payload}}}{N_{\text{governed events}}}} \tag{5.4}$$

Direction Higher is better

Threshold $ATC \geq 0.99$ required

Controls `MON-01`

5.3.5 M-05: Adversarial Defense Rate (ADR)

$$\boxed{ADR = \frac{N_{\text{adversarial tests safely handled}}}{N_{\text{adversarial tests executed}}}} \tag{5.5}$$

Direction Higher is better

Threshold $ADR \geq 0.85$ required

Controls `SEC-01`, `EVAL-01`

5.3.6 M-06: Data Leakage Rate (DLR)

$$\boxed{DLR = \frac{N_{\text{tests exposing protected data}}}{N_{\text{total tests}}}} \tag{5.6}$$

Direction Lower is better

Threshold $DLR \leq 0.01$ required

Controls `DATA-02`, `SEC-01`

5.3.7 M-07: Hallucination/Error Rate (HER)

$$\boxed{HER = \frac{N_{\text{unsupported or factually incorrect claims}}}{N_{\text{total claims evaluated}}}} \tag{5.7}$$

Direction Lower is better

Threshold $HER \leq 0.05$ required

Controls `EVAL-01`

5.3.8 M-08: Unauthorized Access Rate (UAR)

$$\boxed{UAR = \frac{N_{\text{unauthorized access attempts}}}{N_{\text{total runs}}} \times 1000} \tag{5.8}$$

Direction Lower is better

Threshold $UAR \leq 1$ per 1,000 runs

Controls `AGT-02`, `MON-02`

5.3.9 M-09: Sandbox Enforcement Ratio (SER)

$$\boxed{SER = \frac{N_{\text{high-risk runs in sandbox}}}{N_{\text{high-risk runs total}}}} \tag{5.9}$$

Direction Higher is better

Threshold $SER = 1.00$ required for critical tier

Controls `AGT-04`, `SEC-02`

5.4 Statistical evaluation rules

5.4.1 Wilson Lower Confidence Bound

For metrics where "higher is better" (PAR, TCA, ADR, HCC, ATC, SER), use the 95% Wilson lower confidence bound:

$$\boxed{LCB_{95} = \frac{\hat{p} + \frac{z^2}{2n} - z\sqrt{\frac{\hat{p}(1-\hat{p})}{n} + \frac{z^2}{4n^2}}}{1 + \frac{z^2}{n}} \quad \text{where } z = 1.96} \tag{5.10}$$

Production gate rule: A metric passes only if LCB_{95} is greater than or equal to the required threshold.

5.4.2 Why Wilson bounds?

- Wilson bounds are valid for small samples (unlike normal approximation)
- They handle edge cases ($\hat{p} = 0$ or $\hat{p} = 1$) correctly
- They provide conservative estimates appropriate for safety-critical applications

5.4.3 Worked example

Suppose we observe 190 successes out of 200 trials ($\hat{p} = 0.95$):

$$
\begin{aligned}
LCB_{95} &= \frac{0.95 + \frac{1.96^2}{400} - 1.96\sqrt{\frac{0.95 \times 0.05}{200} + \frac{1.96^2}{160000}}}{1 + \frac{1.96^2}{200}} \\
&= \frac{0.95 + 0.0096 - 1.96\sqrt{0.000238 + 0.000024}}{1.019} \\
&= \frac{0.9596 - 0.0317}{1.019} \\
&\approx 0.911
\end{aligned}
$$

If the threshold is 0.90, the metric passes because $LCB_{95} = 0.911 > 0.90$.

5.5 Minimum sample sizes

Table 5.2 – Minimum Sample Sizes by Risk Tier

Risk Tier	Min Scenarios	Repetitions	Total Runs
Low	25	3	75
Medium	50	3	150
High	75	5	375
Critical	100	5	500

5.6 Composite evaluation score

The **Evaluation Score** combines multiple metrics:

$$
\boxed{EVAL_u = 100 \times (0.20 \cdot PAR + 0.15 \cdot TCA + 0.15 \cdot ADR + 0.15 \cdot ATC + 0.10 \cdot HCC + 0.10 \cdot SER) - 100 \times (0.10} \tag{5.11}
$$

5.6.1 EVAL interpretation

Table 5.3 – Evaluation Score Interpretation

Score Band	Interpretation
$EVAL \geq 85$	Excellent, ready for production
$70 \leq EVAL < 85$	Good, minor improvements recommended
$55 \leq EVAL < 70$	Acceptable with conditions
$EVAL < 55$	Not acceptable for production

5.7 Metric thresholds summary

Table 5.4 – Metric Thresholds for Production Gate

Metric	Direction	Threshold	Confidence
PAR	Higher better	≥ 0.95	LCB_{95}
TCA	Higher better	≥ 0.90	LCB_{95}
HCC	Higher better	$= 1.00$	Exact
ATC	Higher better	≥ 0.99	LCB_{95}
ADR	Higher better	≥ 0.85	LCB_{95}
DLR	Lower better	≤ 0.01	UCB_{95}
HER	Lower better	≤ 0.05	UCB_{95}
UAR	Lower better	$\leq 1/1000$	UCB_{95}
SER	Higher better	$= 1.00$ (critical)	Exact

5.8 Domain-Specific Metrics: Text-to-SQL

For Text-to-SQL deployments, an additional 12 metrics extend the core safety framework to address drift between HANA schemas, prompts, and generated SQL. These metrics are fully specified in Chapter 18 of the Simula specification.

5.8.1 TTS Metric Summary

Table 5.5 – Text-to-SQL Drift Metrics (Extension)

ID	Name	Definition	Direction
TTS-M01	Schema Coverage Rate	Fraction of HANA columns in training	Higher
TTS-M02	Schema Staleness Score	Age-weighted unsynced schema changes	Lower
TTS-M03	Column Type Mismatch Rate	Type-incompatible SQL operations	Lower
TTS-M04	Foreign Key Consistency	JOINs following valid FKs	Higher
TTS-M05	Semantic Alignment Score	Prompt-SQL embedding similarity	Higher
TTS-M06	Intent Preservation Rate	Correctly answered prompts	Higher
TTS-M07	Terminology Drift Score	Vocabulary divergence (JSD)	Lower
TTS-M08	Ambiguity Resolution Rate	Disambiguated ambiguous prompts	Higher
TTS-M09	Execution Success Rate	SQL executing without error	Higher
TTS-M10	Result Fidelity Score	Expected vs actual result similarity	Higher
TTS-M11	Complexity Distribution Drift	KL divergence train vs prod	Lower
TTS-M12	Taxonomy Coverage Drift	Change in taxonomy coverage	Lower

5.8.2 TTS-EVAL Composite Score

The TTS Evaluation Score follows the same weighted composite pattern as EVAL:

$$\boxed{\begin{aligned} TTS_EVAL = 100 \times \Big(&0.15 \cdot SCR + 0.10 \cdot (1 - SSS_{\text{norm}}) + 0.10 \cdot FKCR \\ &+ 0.15 \cdot SAS + 0.10 \cdot IPR + 0.15 \cdot ESR \\ &+ 0.10 \cdot RFS + 0.05 \cdot ARR\Big) \\ -100 \times \Big(&0.05 \cdot CTMR + 0.03 \cdot TDS + 0.02 \cdot CDD\Big) \end{aligned}} \tag{5.12}$$

5.8.3 TTS Metric Thresholds

5.8.4 Relationship to Core Safety Metrics

The TTS metrics complement, not replace, the core 12 safety metrics:

- **M-02 (Tool Call Accuracy)** maps to **TTS-M09 (ESR)** for SQL execution
- **M-04 (Audit Trace Completeness)** is satisfied by TTS drift telemetry tables
- **M-07 (Hallucination Rate)** maps to **TTS-M06 (IPR)** for intent preservation

For complete TTS drift metric definitions, formulas, and implementation details, see `docs/latex/specs/simula/chapters/18-text-to-sql-drift.tex`.

Table 5.6 – TTS Metric Thresholds for Production Gate

Metric	Direction	Threshold
TTS-M01 (SCR)	Higher better	≥ 0.85
TTS-M02 (SSS)	Lower better	≤ 7.0 days
TTS-M03 (CTMR)	Lower better	≤ 0.02
TTS-M04 (FKCR)	Higher better	≥ 0.95
TTS-M05 (SAS)	Higher better	≥ 0.80
TTS-M06 (IPR)	Higher better	≥ 0.90
TTS-M07 (TDS)	Lower better	≤ 0.15
TTS-M08 (ARR)	Higher better	≥ 0.75
TTS-M09 (ESR)	Higher better	≥ 0.95
TTS-M10 (RFS)	Higher better	≥ 0.85
TTS-M11 (CDD)	Lower better	≤ 0.10
TTS-M12 (TCD)	Lower better	≤ 0.05
TTS-EVAL	Higher better	≥ 70 (production)

5.9 Persona-Aware Safety Metrics (PER-M01 to PER-M04)

For AI systems serving diverse user populations and agent workers with varying levels of domain expertise, the following persona-aware metrics ensure fair and appropriate treatment across all communicator types.

5.9.1 Metric Definitions

Table 5.7 – Persona-Aware Safety Metrics (4 Metrics)

ID	Name	Definition	Safety Link
`PER-M01`	Persona Coverage Rate	Fraction of personas with adequate training data	S-08 (Data Quality)
`PER-M02`	Expertise Consistency	Fraction of prompts matching persona expertise	S-01 (Accuracy)
`PER-M03`	Cross-Persona Fairness	Maximum deviation from uniform persona coverage	S-04 (Fairness)
`PER-M04`	Per-Persona Drift Score	SSG Z-score computed per persona	S-02 (Robustness)

5.9.2 PER-M01: Persona Coverage Rate

$$\boxed{PER_M01 = \frac{|\{p : N_p \geq N_{\text{min}}\}|}{|P|}} \tag{5.13}$$

Variables P = set of all defined personas; N_p = training samples for persona p; N_{min} = minimum samples (default 100)

Direction Higher is better

Threshold $PER_M01 \geq 0.95$ required

Safety Link S-08 (Data Quality) — ensures training data represents all user types

5.9.3 PER-M02: Expertise Consistency Rate

$$\boxed{PER_M02 = \frac{N_{\text{prompts matching persona complexity/terminology}}}{N_{\text{total}}}} \tag{5.14}$$

Definition A prompt "matches" if its complexity and terminology precision fall within the expected range for its persona

Direction Higher is better

Threshold $PER_M02 \geq 0.90$ required

Safety Link S-01 (Accuracy) — system accurately reflects user expertise

5.9.4 PER-M03: Cross-Persona Fairness

$$\boxed{PER_M03 = \max_{i \in P} |p_i - \bar{p}| \quad \text{where} \quad \bar{p} = \frac{1}{|P|}} \tag{5.15}$$

Definition Maximum deviation from uniform persona distribution

Direction Lower is better

Threshold $PER_M03 \leq 0.10$ required (no persona overrepresented by $> 10\%$)

Safety Link S-04 (Fairness) — no persona is disadvantaged

5.9.5 PER-M04: Per-Persona Drift Score

$$\boxed{PER_M04^{(p)} = \frac{|x_t^{(p)} - \hat{x}_t^{(p)}|}{\sigma_t^{(p)}}} \tag{5.16}$$

Observable Prompt embedding distance from persona p's training centroid

Direction Lower is better

Threshold $PER_M04^{(p)} < 2.0$ for each persona (95% confidence)

Safety Link S-02 (Robustness) — system remains stable across persona drift

5.9.6 Persona Metric Thresholds

Table 5.8 – Persona Metric Thresholds by Population Type

Metric	Human Threshold	Agent Threshold	Rationale
PER-M01	≥ 0.95	≥ 0.95	Equal coverage required
PER-M02	≥ 0.85	≥ 0.95	Agents must be more consistent
PER-M03	≤ 0.10	≤ 0.10	Fairness for all
PER-M04	$Z < 2.5$	$Z < 2.0$	Agents have stricter drift tolerance

5.9.7 Relationship to Core Safety Metrics

The persona metrics extend the core safety framework:

- **S-01 (Accuracy)** is decomposed by persona via **PER-M02**
- **S-02 (Robustness)** is monitored per-persona via **PER-M04**
- **S-04 (Fairness)** is quantified via **PER-M03**
- **S-06 (Explainability)** requires persona classification rationale in audit trails
- **S-08 (Data Quality)** is ensured via **PER-M01**

For complete persona taxonomy and generation pipeline details, see `docs/latex/specs/simula/chapters/19-financial-prompt-generation.tex`.

CHAPTER 6

6 Monitoring, Alerting, and Audit Schema

6.1 Monitoring objectives

Post-deployment monitoring serves four objectives:

1. **Detect policy violations and drift** in real-time
2. **Maintain complete audit trail** for governance evidence
3. **Enable rapid incident response** and containment
4. **Support continuous improvement** through metrics analysis

6.2 Required audit schema

Every governed execution must record the following fields per 📁 `docs/schema/regulations/audit-event.schema.json`:

Table 6.1 – Required Audit Event Fields

Field	Type	Description
`event_id`	string	Unique audit event identifier (e.g., evt-20260422-abc123)
`event_type`	enum	Discriminator: agent_inference, agent_write, review_requested, review_approved, review_rejected, agent_error
`timestamp`	datetime	ISO 8601 timestamp when event was recorded
`request_identity`	object	Request ID, correlation ID, user ID, tenant ID
`agent_identity`	object	Agent ID, type, version, service name, deployment ID
`action`	object	Action type, entity ID, input/output hashes
`approval_chain`	array	Ordered approval steps if HITL invoked
`outcome`	object	Status (success/failure/pending), duration_ms, error_code

6.3 Identity attribution requirements

Per `AGT-03` and REG-MGF-2.1.2-002, every action must be attributable:

6.3.1 Agent identity fields

- `agent_id`: Unique identifier for the agent instance

- `agent_type`: Classification (e.g., predictive-analytics)
- `agent_version`: Semantic version of agent code
- `service_name`: Hosting service identifier
- `deployment_id`: Specific deployment instance
- `model_id`: Underlying model identifier
- `trust_level`: Autonomy level (L1–L4)

6.3.2 Request identity fields

- `request_id`: Unique request identifier
- `correlation_id`: Correlation ID for distributed tracing
- `user_id`: Requesting user (if applicable)
- `tenant_id`: Tenant context
- `timestamp`: Request timestamp

6.4 Audit reservation pattern

The **reservation-before-action** pattern ensures audit completeness:

1. **Reserve**: Before executing an action, reserve an audit event with status “reserved”
2. **Execute**: Perform the action
3. **Complete**: Update the audit event with outcome (success/failure)

If the action crashes without completing the audit, the reservation becomes an “orphan” that indicates a governance failure requiring investigation.

Critical Requirement

No irreversible action may execute without a successful audit reservation. If the reservation fails, the action must be blocked.

6.5 Alert severity classes

Table 6.2 – Alert Severity Classes

Severity	Response Time	Example Conditions
Critical	< 15 minutes	Identity missing, audit failure, circuit breaker open
High	< 1 hour	Orphaned audit, topic drift, latency spike
Medium	< 4 hours	Metric degradation, approval bottlenecks
Informational	Next business day	Successful operations, recovered services

6.6 Condition codes

Condition codes provide machine-readable alert classification:

6.7 Circuit-break rules

Circuit breakers protect against cascade failures:

Table 6.3 – Governance Condition Codes

Code	Severity	Control	Description
REG-ING-001	Critical	AGT-02	Tool called not in allow-list
REG-ING-002	Critical	AGT-03	Identity envelope missing
REG-AUD-001	Critical	MON-01	Audit reservation failed
REG-AUD-002	High	MON-01	Orphaned audit event detected
REG-SCHEMA-001	High	MON-01	Audit payload schema violation
REG-DRIFT-001	High	EVAL-01	Topic similarity below threshold
REG-LATENCY-001	High	MON-02	P95 latency exceeded threshold
REG-REFUSAL-001	Medium	EVAL-01	Refusal rate elevated
REG-CB-001	Critical	MON-02	Circuit breaker opened

Table 6.4 – Circuit-Break Triggers

Trigger Condition	Duration	Recovery
3 consecutive critical alerts in 15 minutes	Open until manual close	Human verification required
5 consecutive failed health checks	30 seconds auto-retry	Auto-close on success
> 10% error rate in 5-minute window	Open until manual close	Investigation required

6.8 Drift and anomaly detection

6.8.1 Population Stability Index (PSI)

For detecting distribution drift in model inputs/outputs:

$$\boxed{PSI = \sum_{i=1}^{k} (A_i - E_i) \cdot \ln\left(\frac{A_i}{E_i}\right)} \tag{6.1}$$

where A_i is actual proportion in bin i and E_i is expected proportion.

Table 6.5 – PSI Interpretation

PSI Range	Interpretation
$PSI < 0.10$	No significant drift
$0.10 \leq PSI < 0.25$	Moderate drift, investigate
$PSI \geq 0.25$	Significant drift, action required

6.8.2 Robust Z-Score

For anomaly detection with outlier resistance:

$$\boxed{Z_{\text{robust}} = \frac{x - \text{median}(X)}{1.4826 \times \text{MAD}(X)}} \tag{6.2}$$

where MAD is the Median Absolute Deviation. The factor 1.4826 normalizes MAD to be consistent with standard deviation for normal distributions.

Table 6.6 – Z-Score Thresholds

Z-Score	Action
$\lvert Z\rvert < 2$	Normal
$2 \leq \lvert Z\rvert < 3$	Monitor
$\lvert Z\rvert \geq 3$	Alert

6.9 Required alert payload

Every alert must include:

Table 6.7 – Required Alert Payload Fields

Field	Type	Description
`request_id`	string	Request that triggered the alert
`correlation_id`	string	Correlation for distributed tracing
`agent_id`	string	Agent that generated the condition
`severity`	enum	Critical, High, Medium, Informational
`condition_code`	string	Machine-readable condition code
`condition_message`	string	Human-readable description
`evidence_source`	string	Path to supporting evidence
`observed_value`	string	The value that triggered the alert
`threshold_value`	string	The threshold that was violated
`recommended_action`	string	Suggested remediation
`timestamp`	datetime	When the condition was detected

6.10 Operator triage checklist

When an alert is received:

1. Confirm the request_id and correlation_id
2. Confirm the agent_id and deployment context
3. Confirm the condition_code and severity
4. Verify the observed value against the threshold
5. Check the evidence source for additional context
6. Determine if this is a known issue (check Known Issues Registry)
7. Execute recommended action or escalate
8. Document resolution in incident ticket

6.11 Minimum evidence to close an alert

- Root cause identified
- Mitigation applied
- Audit trail shows successful processing post-fix
- No recurrence within observation window (15 minutes minimum)

CHAPTER 7

7 Implementation Design

7.1 Repository structure

The governance framework is implemented across several repository paths:

7.2 Governance module architecture

The governance module in `src/intelligence/ai-core-pal/governance/` consists of three components:

Table 7.1 – Key Implementation Paths

Path	Purpose
`src/intelligence/ai-core-pal/governance/`	Identity and audit modules
`src/intelligence/ai-core-pal/agent/governed\_agent.py`	Governance-compliant agent
`src/intelligence/.clinerules`	Development agent rules
`src/intelligence/.clinerules.runtime-monitor`	Runtime monitor rules
`src/generativeUI/gateway/.clinerules.runtime-monitor`	Gateway ingress overlay
`docs/schema/regulations/`	JSON Schemas for governance contracts
`docs/latex/specs/regulations/`	Regulations corpus specification
`docs/latex/specs/singapore-ai-safety/`	This specification

7.2.1 Identity module (`identity.py`)

Implements identity attribution per REG-MGF-2.1.2-002:

- `AgentIdentity`: Dataclass for agent identity fields, validated against `agent-identity.schema.json`
- `RequestIdentity`: Dataclass for request identity fields, validated against `request-identity.schema.json`
- `IdentityEnvelope`: Combined envelope for governance tracking
- `IdentityProvider`: Factory for creating and validating identity envelopes

7.2.2 Audit module (`audit.py`)

Implements durable audit trail per REG-MGF-2.3.3-002:

- `AuditEvent`: Dataclass for audit events, validated against `audit-event.schema.json`
- `AuditReservation`: Reservation-before-action pattern

- `DurableAuditStore`: SQLite-backed persistent storage
- Support for reservation, completion, orphan detection

7.2.3 Governed agent (📁 `governed\_agent.py`)

Implements the full governance flow:

1. Create identity envelope
2. Validate envelope
3. Check tool allow-list (deny-by-default)
4. Check approval requirements
5. Reserve audit BEFORE action
6. Execute action
7. Complete audit AFTER action

7.3 JSON schemas

Governance contracts are defined in machine-readable JSON Schema format:

7.4 Agent rule packs

Two complementary rule packs govern agent behavior:

Table 7.2 – Governance JSON Schemas

Schema	Purpose
`agent-identity.schema.json`	Agent identity fields and validation
`request-identity.schema.json`	Request identity fields and validation
`audit-event.schema.json`	Audit event structure with oneOf variants
`requirement.schema.json`	Regulatory requirement with status tracking
`regulation.schema.json`	Source regulation metadata
`conformance-tool.schema.json`	AI Verify / Moonshot tool references

7.4.1 Development pack (`.clinerules`)

Guides agent development with:

- Source of truth references
- Definition of done criteria
- Non-negotiable engineering rules
- Known issue registry
- Default thresholds

7.4.2 Runtime-monitor pack (`.clinerules.runtime-monit`

Guides runtime monitoring with:

- Condition codes and severities
- Alert thresholds
- Circuit-break triggers
- Evidence sources

- Operator triage checklist

7.5 Compliance requirements mapping

Table 7.3 – Implementation Status by Requirement

Requirement	Status	Implementation
REG-MGF-2.1.2-001	Implemented	`GovernedGovernanceEngine.ALLOWED_TOOLS`
REG-MGF-2.1.2-002	Implemented	`IdentityProvider`, `IdentityEnvelope`
REG-MGF-2.1.2-003	Partial	Sandboxing via container isolation
REG-MGF-2.2.2-001	Implemented	`APPROVAL_REQUIRED_TOOLS`
REG-MGF-2.3.3-002	Implemented	`DurableAuditStore`
Chapter 10 Audit	Implemented	Reservation-before-action pattern

7.6 Integration points

7.6.1 MCP tool allow-list

The governance engine maintains an explicit allow-list:

```
ALLOWED_TOOLS = frozenset({
    "pal_classification",
    "pal_regression",
    "pal_clustering",
```

```
    "pal_forecast",
    "pal_anomaly",
})
```

Any tool not in this list is blocked (deny-by-default).

7.6.2 Approval-required tools

High-risk tools require human approval:

```
APPROVAL_REQUIRED_TOOLS = frozenset({
    "pal_train_model",
    "pal_delete_model",
    "hana_write",
    "model_deploy",
})
```

7.6.3 Audit database schema

The SQLite audit database contains:

```
CREATE TABLE audit_events (
    event_id TEXT PRIMARY KEY,
    event_type TEXT NOT NULL,
    timestamp TEXT NOT NULL,
    request_id TEXT NOT NULL,
    correlation_id TEXT NOT NULL,
    agent_id TEXT NOT NULL,
    agent_type TEXT NOT NULL,
    status TEXT NOT NULL,
    duration_ms INTEGER,
    tokens_used INTEGER,
    error_code TEXT,
    action_json TEXT,
```

```
    approval_chain_json TEXT,
    request_identity_json TEXT NOT NULL,
    agent_identity_json TEXT NOT NULL,
    full_event_json TEXT NOT NULL,
    is_orphaned INTEGER DEFAULT 0
);
```

7.7 Testing and validation

7.7.1 Validation harness

The validation harness at `src/intelligence/ai-core-pal/tests/test\_clinerules\_contracts.py` validates:

- Structural completeness of rule packs
- Safety-critical flag inheritance (no weakening)
- Regulatory alignment requirements
- Cross-pack consistency
- Schema references

7.7.2 Running validation

```
# Run full validation
python src/intelligence/ai-core-pal/tests/test_clinerules_contracts.py

# Run with pytest
pytest src/intelligence/ai-core-pal/tests/test_clinerules_contracts.py -v
```

7.8 Deployment checklist

Before deploying a governance-compliant agent:

1. Verify all schemas exist and validate
2. Verify rule packs pass validation harness
3. Verify audit database is accessible
4. Verify identity provider is configured
5. Verify tool allow-list is correct for use case
6. Calculate risk scores and verify production gate criteria
7. Run minimum sample size tests per risk tier
8. Confirm monitoring and alerting are active

CHAPTER 8

8 References

8.1 Singapore Government sources

8.1.1 Primary normative sources

1. IMDA. *Model AI Governance Framework for Agentic AI*. Singapore: Infocomm Media Development Authority, January 2026.

    - Pillar 1: Assess and Bound Risks Upfront
    - Pillar 2: Make Humans Meaningfully Accountable
    - Pillar 3: Implement Technical Controls and Processes
    - Pillar 4: Enable End-User Responsibility

2. IMDA. *Starter Kit for Testing LLM-Based Applications for Safety and Reliability*. Singapore: Infocomm Media Development Authority, January 2026.

3. PDPC. *Model AI Governance Framework, Second Edition*. Singapore: Personal Data Protection Commission, January 2020.

4. PDPC. *Advisory Guidelines on Use of Personal Data in AI Recommendation and Decision Systems*. Singapore: Personal Data Protection Commission, April 2024.

8.1.2 Supplementary sources

5. IMDA. *Project Moonshot, powered by AI Verify*. Singapore: Infocomm Media Development Authority, May 2024. URL: https://aiverifyfoundation.sg/project-moonshot/

6. IMDA. *Singapore's Approach to AI Governance*. Singapore: Infocomm Media Development Authority. Ongoing.

7. CSA. *Guidelines and Companion Guide on Securing AI Systems*. Singapore: Cyber Security Agency, October 2024.

8. CSA. *Public Consultation on Securing Agentic AI Systems*. Singapore: Cyber Security Agency, October 2025. (Consultation-stage)

8.2 Open-source tools and frameworks

1. AI Verify Foundation. *AI Verify*. Open-source AI governance testing framework and target toolkit. URL: https://github.com/aiverify-foundation/aiverify

2. AI Verify Foundation. *Project Moonshot*. Red-teaming and benchmarking toolkit for LLM-based applications. URL: https://github.com/aiverify-foundation/moonshot

8.3 Internal specifications

1. **Agentic AI Regulations Corpus.** `docs/latex/specs/regulations/regulations-spec.tex`

   Comprehensive regulatory requirements derived from Singapore government sources with implementation evidence tracking.

2. **Agent Rule-Pack Architecture.** `docs/latex/specs/clinerules-agents/`

   Specification for .clinerules rule packs governing agent development and runtime monitoring.

3. **Trial Balance HITL Specification.** `docs/latex/specs/tb/`

   Human-in-the-loop workflow specification for Trial Balance review.

4. **Arabic AP Processing Specification.** `docs/latex/specs/arabic/`

   Accounts Payable OCR and processing specification.

5. **Simula Training Specification.** `docs/latex/specs/simula/`

   Training and deployment specification for Simula models.

8.4 JSON schemas

1. `docs/schema/regulations/agent-identity.schema.json` — Agent identity validation
2. `docs/schema/regulations/request-identity.schema.json` — Request identity validation
3. `docs/schema/regulations/audit-event.schema.json` — Audit event structure
4. `docs/schema/regulations/requirement.schema.json` — Regulatory requirement structure
5. `docs/schema/regulations/regulation.schema.json` — Source regulation metadata
6. `docs/schema/regulations/conformance-tool.schema.json` — Conformance tool references

7. `docs/schema/regulations/corpus.schema.json` — Full corpus structure

8.5 Source document locations

Table 8.1 – Source Document Repository Locations

Document	Repository Path
MGF for Agentic AI	`docs/regulations/mgf-for-agentic-ai.pdf`
AI Verify toolkit	`docs/regulations/aiverify-main/`
Project Moonshot	`docs/regulations/moonshot-cicd-main/`
2025 AI Agent Index	`docs/regulations/2025-AI-Agent-Index.pdf`
Singapore AI Safety Framework	`docs/pdf/technical-reports/06-singapore-ai-safety-framework.pdf`

8.6 Version history

Table 8.2 – Specification Version History

Version	Date	Author	Changes
1.0.0	2026-04-22	SAP-OSS AI Governance Team	Initial specification

8.7 Document control

Document ID SG-SAFETY-2026-v1.0

Classification Internal

Review Cycle Quarterly

Next Review 2026-07-22

Owner SAP-OSS AI Governance Team

Approver Controls Architecture Lead

CHAPTER 9

9 Global Wave-Dependency Manifest

9.1 Critical Path Visualization (Waves 1–3)

The following chart defines the normative sequencing for implementation agents. A task in a later wave cannot be marked complete until its prerequisites in an earlier wave are validated.

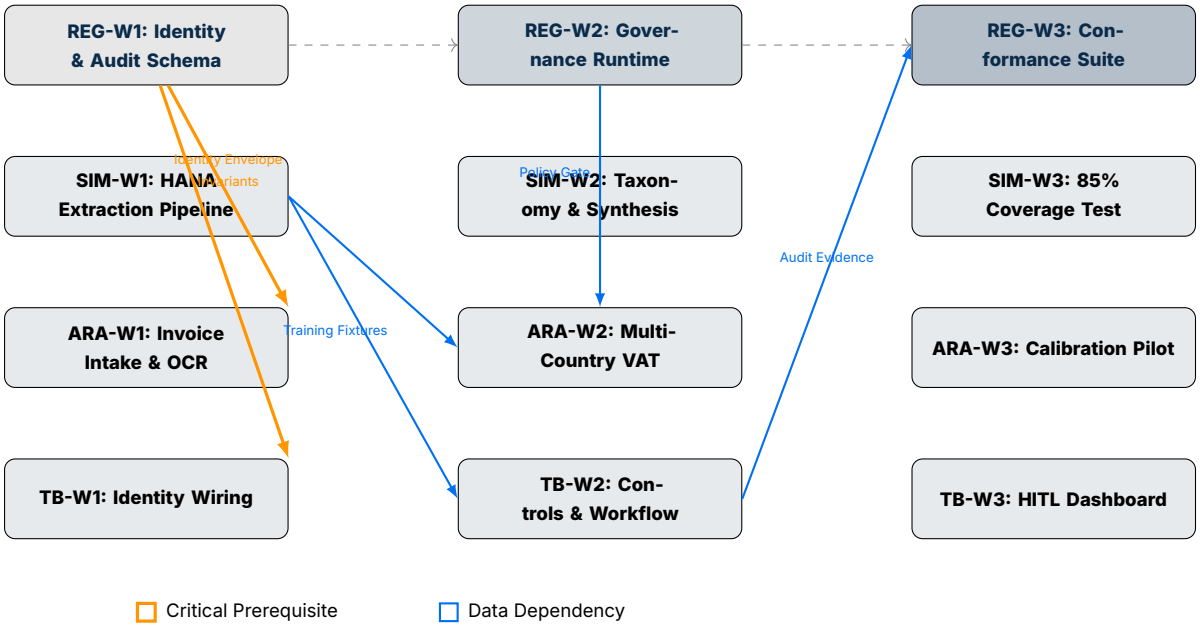

Figure 9.1 – Cross-specification dependency graph: The blueprint for platform rollout.

9.2 Inter-Domain Prerequisite Matrix

Dependency Enforcement

Implementation agents are strictly forbidden from "Fast-Forwarding" into Wave 2 if Wave 1 critical prerequisites (marked in **Gold**) are in a gap or partial state.

Table 9.1 – Normative Cross-Domain Prerequisites.

Target Task	Prerequisite	Ref ID	Rationale
ARA-W1	REG-W1 (Identity)	`REG-IDENTITY-01`	Invoice intake must be audit-traced from Day 1.
TB-W2	SIM-W1 (Extraction)	`SIM-EXTRACT-01`	Anomaly detection requires HANA schema metadata.
REG-W2	SIM-W1 (Registry)	`SIM-REGISTRY-01`	Governance monitoring relies on the schema registry.
ARA-W2	REG-W2 (Pillar 1)	`REG-MGF-P1`	VAT release is an HITL gate governed by MAS Pillar 1.
TB-W3	ARA-W2 (Posted Invoices)	`ARA-AP-POST`	Review dashboard depends on posted AP data from Arabic domain.

This specification is part of the SAP-OSS AI Platform documentation suite.
Singapore AI Safety Framework aligned with IMDA MGF and CSA guidelines.
For questions or feedback, contact the AI Governance Team.

Typeset with XeLaTeX using the sap-oss-apple document class.
Typography: Inter (body), JetBrains Mono (code).
Version 1.0.0 • April 2026